UP
Universidad
de Palermo

INGENIERIA REVERSA

Clase 1

Universidad de Palermo

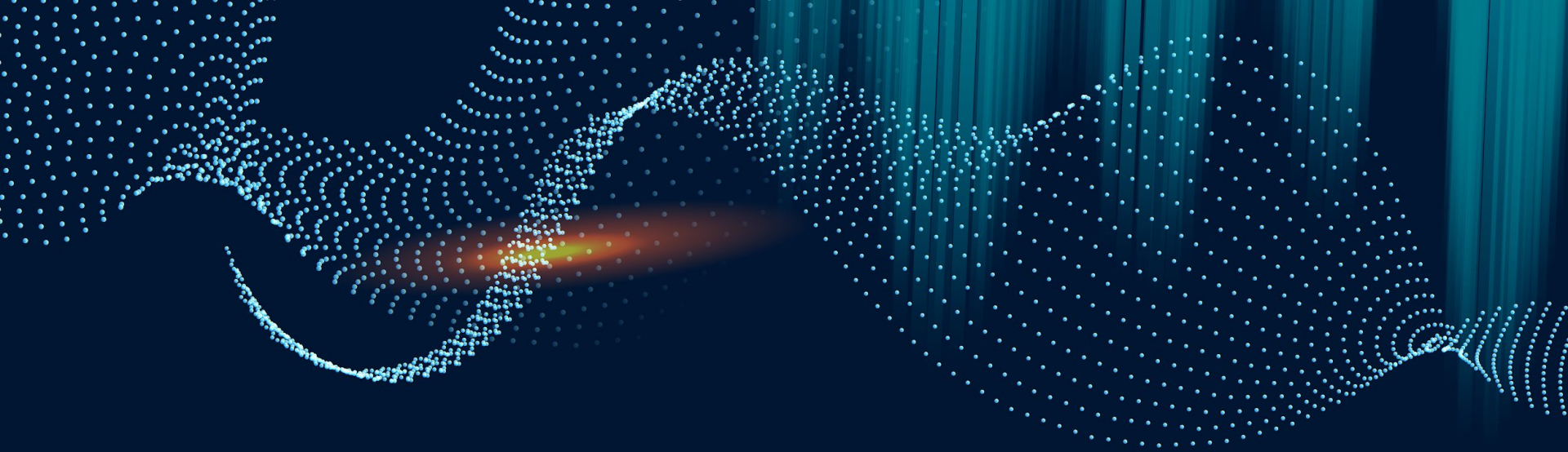


PRESENTACIÓN

Vamos a conocernos y a conocer la materia

Lo que vamos a ver en la materia

1. Definiciones, ética, vectores, etc.
2. Análisis estático básico y avanzado.
3. Análisis dinámico básico y avanzado.
4. Análisis e identificación de distintas estructuras programáticas.
5. Armado de laboratorio.
6. TTPS (Tactics, Techniques and Procedures).
7. Herramientas y técnicas.
8. Elaboración de reportes.
9. **Explotar máquinas virtuales por los aires.**
10. Análisis de una muestra real.



01 INTRODUCCIÓN

¿Qué es la Ingeniería Reversa/Inversa?

“El proceso de desmontar y examinar un producto o dispositivo para descubrir los conceptos involucrados en su fabricación, generalmente con el objetivo de producir algo similar”

—The Merriam-Webster Dictionary, New ed. 2004.

“Ingeniería inversa es como ser un detective, reuniendo pistas para descubrir el funcionamiento interno de un software o hardware. Esta habilidad se puede utilizar para el bien, cómo corregir errores, pero también se puede utilizar para robar secretos o explotar fallos de seguridad.”

—Juan de los Palotes

¿Qué es?

La ingeniería inversa es analizar un producto para entender cómo funciona y está hecho. Se usa en varias industrias para mejorar productos, analizar fallas y más.

¿Para qué sirve?

Fomenta la innovación, permite aprender de la competencia, ayuda a solucionar problemas, reduce costos de desarrollo y revela vulnerabilidades.

¿Cómo se hace?

Se recopila información, se crea un modelo, se desmonta el producto, se evalúan las piezas y se vuelve a armar para confirmar lo aprendido.

BENEFICIOS/OBJETIVOS

- *“Explorar”* productos existentes
- Reparación de productos existentes
- Descubrir vulnerabilidades del producto
- Innovación
- Análisis de fallos
- Realizar análisis de la competencia
- Reducir los costos de desarrollo de productos



CASOS DE USO



Debugging

Entender cómo funciona un software



Seguridad

Identificar vulnerabilidad, fallas de sistemas, etc.



Interoperabilidad

Entender cómo se comunican dos productos



Compatibilidad

Mejorar la compatibilidad entre productos

ALGUNAS HISTORIAS



Compaq

Compaq utilizó la ingeniería inversa para crear su primer PC compatible con IBM, el Compaq Portable



Enigma

Era un dispositivo de cifrado utilizado por los alemanes durante la Segunda Guerra Mundial



Arquimedes

El tornillo de Arquímedes, un dispositivo inventado en el siglo III a.C. para elevar agua.

“El análisis de malware es el arte de entender cómo funciona, cómo identificarlo y cómo derrotarlo y eliminarlo”

—Michael Sikorski

OBJETIVOS DEL ANÁLISIS DE MALWARE

Identificación de vulnerabilidades	Desarrollo de firmas de detección	Análisis del comportamiento
Atribución de ataques	Creación de herramientas de desinfección	Prevención de futuros ataques

INDICADORES

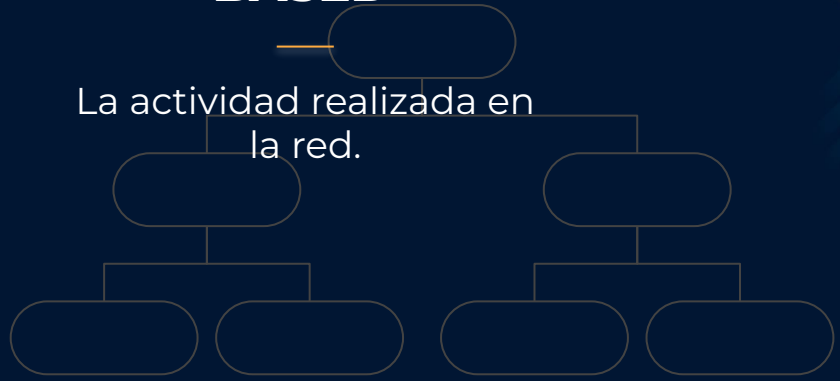


HOST BASED

Indicadores obtenidos de la máquina infectada.

NETWORK BASED

La actividad realizada en la red.



TÉCNICAS

ANÁLISIS ESTÁTICO

- Se divide en básico y avanzado
- Analizamos el software sin ejecutarlo

ANÁLISIS DINÁMICO

- Se divide en básico y avanzado
- Analizamos el software mientras se ejecuta

TIPOS DE ANÁLISIS

	BÁSICO	AVANZADO
ESTÁTICO	Examinar el ejecutable sin ver las instrucciones	Consiste en analizar las instrucciones del ejecutable utilizando un desensamblador
DINÁMICO	Ejecuta el malware y analiza su comportamiento en el sistema.	Consiste en la utilización de un debugger para analizar el ejecutable mientras se ejecuta

REGLAS GENERALES



PRAGMATISMO

No perderse en los detalles.



HERRAMIENTAS

Son muchas y todas tienen sus ventajas y desventajas, hay que recordar utilizarlas

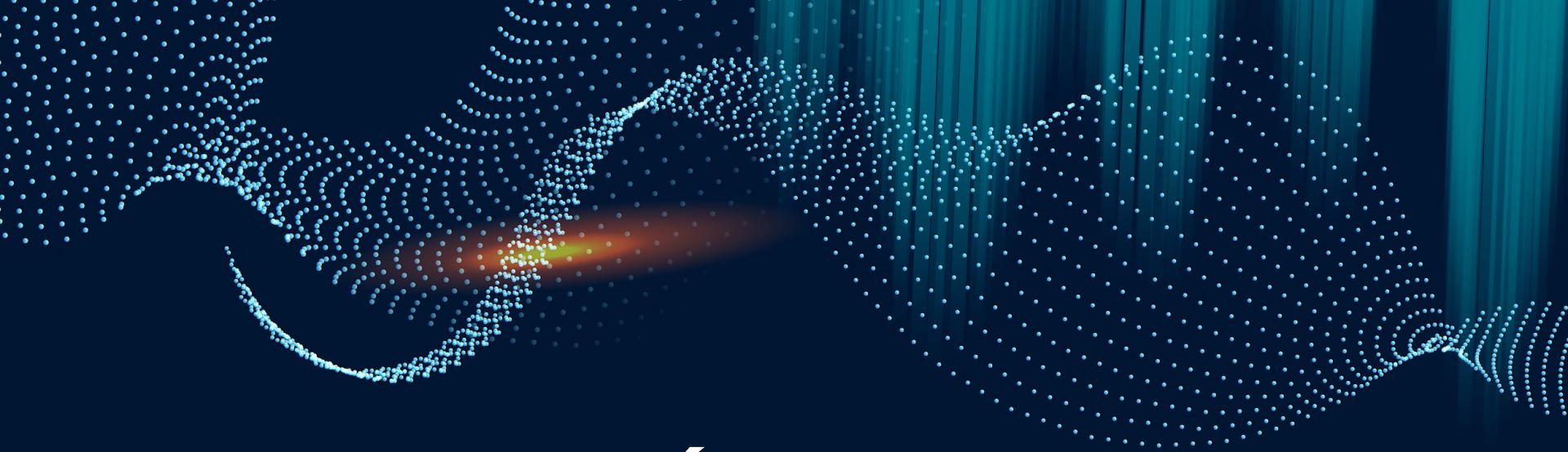


EVOLUCIÓN

Este juego nunca termina, cuando alguien encuentra la solución a una pregunta, se crean 10 más

CAPACIDADES QUE NOS PUEDEN AYUDAR

- Programación básica
- Herramientas de depuración y desensamblado
- Técnicas de análisis de malware
- Componentes internos del sistema operativo
- Protocolos de red y seguridad
- Resolución de problemas y pensamiento crítico



02

ÉTICA Y LEGALIDAD

Aspectos legales y éticos

CONSIDERACIONES LEGALES EN EL ANÁLISIS DE MALWARE

01

LEGISLACIÓN INTERNACIONAL

02

LEGISLACIÓN NACIONAL

03

OTRAS LEYES O NORMATIVAS RELEVANTES





Acuerdos de licencia

Respetar los términos de uso de software y herramientas de análisis.

Acceso no autorizado

Evitar el acceso ilegal a sistemas o datos durante el análisis.

Evidencia forense

Mantener la integridad de la evidencia para posibles investigaciones.

CONSIDERACIONES ÉTICAS EN EL ANÁLISIS DE MALWARE



Intención

Comprender y mitigar amenazas



Privacidad

Respetar la privacidad de los usuarios



Daño colateral

Minimizar los riesgos de daños no deseados



Transparencia

Compartir la información de manera responsable

DIVULGACIÓN RESPONSABLE

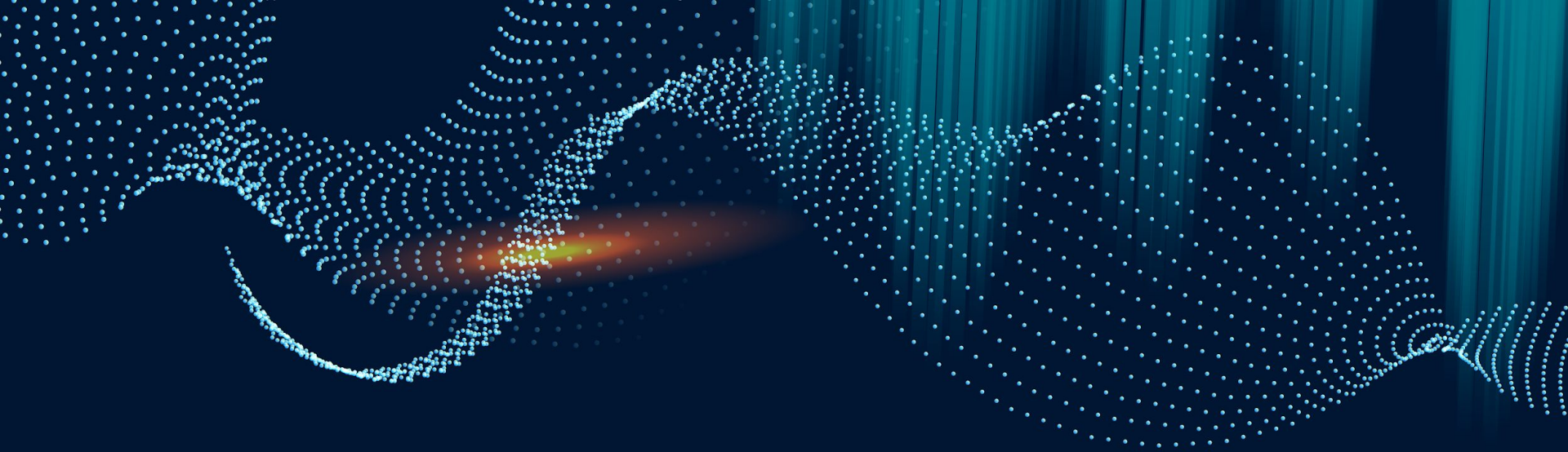
Informar de manera ética y controlada sobre fallos de seguridad a los desarrolladores o proveedores.

- **Objetivo:** Permitir que se solucionen las vulnerabilidades antes de que sean explotadas por atacantes.
- **Mejora de la seguridad:** Permite corregir vulnerabilidades y fortalecer sistemas.
- **Protección de usuarios:** Reduce el riesgo de ataques y pérdida de datos.
- **Fomento de la confianza:** Demuestra compromiso con la seguridad y la transparencia.
- **Colaboración:** Promueve la cooperación entre investigadores y desarrolladores.

RESPONSABILIDADES DEL ANALISTA DE MALWARE - CONCLUSIONES

- Comprender y seguir las leyes y regulaciones pertinentes.
- Obtenga la autorización adecuada antes de acceder o analizar los sistemas.
- Evite causar daños o interrumpir los sistemas durante el análisis.
- Respete la privacidad del usuario y evite el acceso no autorizado a los datos.
- Mantener la confidencialidad de la información sensible.
- Informar los hallazgos de manera responsable y ética.

El analista debe proteger y protegerse, por eso debe actuar con responsabilidad y conciencia.



03

TIPOS DE MALWARE

¿A que nos enfrentamos?



LAS COSAS POR SU NOMBRE

No es fácil llegar a un acuerdo cuando se trata de nombrar e identificar a un malware

SITUACIÓN ACTUAL

La nomenclatura y terminología del malware carece de estandarización y consenso.

- Las familias y variantes de malware tienen varios nombres
- Un nombre utilizado simultáneamente para varias familias.
- Las familias de malware se mezclan con su nombre de detección
- Las familias de malware se mezclan con su “modo de entrega”.
- El significado de un nombre puede cambiar con el tiempo.
- El significado de un nombre puede depender de la persona u organización que lo utilice.
- Se utiliza el mismo nombre para la familia y el tipo de malware.

DISTINTAS MANERAS DE DECIR LO MISMO

	FORMAT	EXAMPLE
Avast	Platform:Type1-Modifier \[Type2\]	VBS:Downloader-ARK [Trj]
AVG	Type Family.Variant	Trojan horse Crypt8.BHVG
Avira	Modifier/[Type.]Family.Variant	TR/Inject.xbbeicg
Bitdefender	[Modifier:[Platform.]]Type.Family[.Modifier].Variant	Gen:Trojan.Mresmon.Gen.1
ESET	[Modifier] Platform/[Type.]Family.Variant Type	a variant of MSIL/TrojanDropper.Agent.BPM trojan
Kaspersky	[Modifier:]Type.Platform.Family[.Variant]	HEUR:Trojan.Win32.Nymaim.gen

Backdoor:	**Win32/**	**Caphaw**	**.D**	**!Ink**
Tipo:	Plataforma/	Familia	Variante	!Suffixes



Backdoor:Win32/Caphaw.D!Ink

Nombres de Malware
Microsoft

TIPOS

- Adware
- Backdoor
- Behavior
- BrowserModifier
- Constructor
- DDoS
- Exploit
- HackTool
- Joke
- Misleading
- MonitoringTool
- Program
- Personal Web Server (PWS)
- Ransom
- RemoteAccess
- Rogue
- SettingsModifier
- SoftwareBundler
- Spammer
- Spoofer
- Spyware
- Tool
- Trojan
- TrojanClicker
- TrojanDownloader
- TrojanNotifier
- TrojanProxy
- TrojanSpy
- VirTool
- Virus
- Worm

LOS MÁS CONOCIDOS

WORMS

Se propagan por la red sin necesidad de archivos.

VIRUSES

Infectan archivos y se replican al ejecutarlos.

TROJANS

Se disfrazan para engañar y abrir puertas traseras.

BACKDOORS

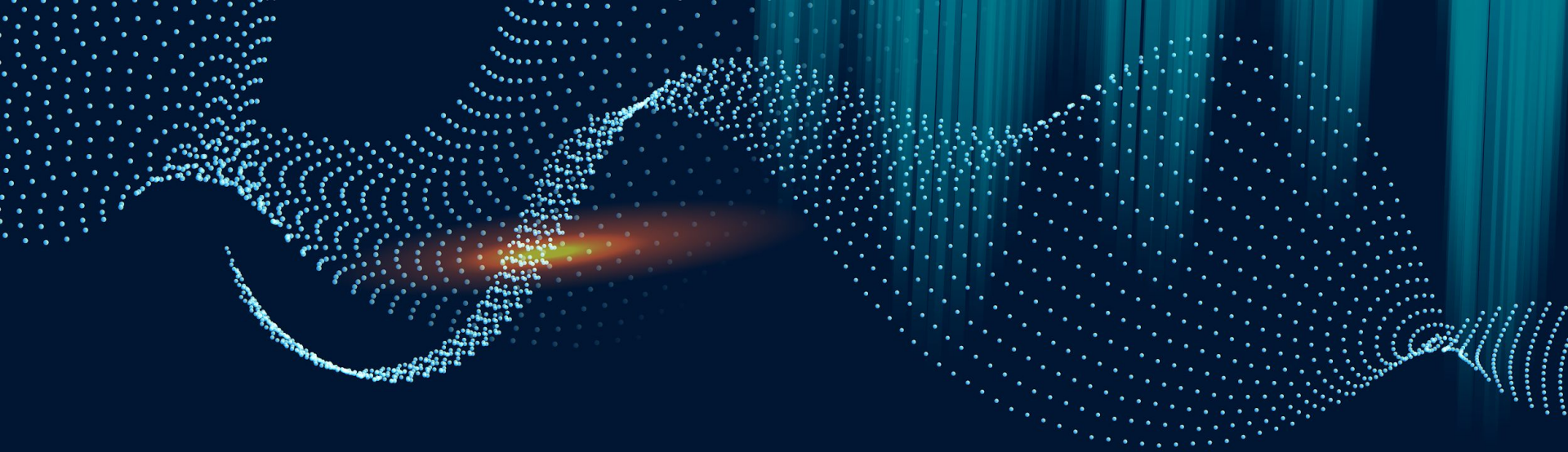
Permiten acceso remoto no autorizado al sistema.

RANSOMWARE

Cifra datos y exige rescate para recuperarlos.

EXPLOIT

Aprovecha vulnerabilidades para ejecutar código malicioso.



04 MÉTODOS

Vectores de ataque, ciclo de vida y técnicas comunes de infección

“TTP: Tácticas, Técnicas y Procedimientos, son los métodos, comportamientos o patrones de actividad utilizados por un actor de amenazas o un grupo de actores de amenazas.

—Mitre

TTP: Entender al adversario



TÁCTICA

Objetivo general del atacante.



TÉCNICA

Método para lograr la táctica.



PROCEDIMIENTO

Pasos detallados de la técnica.

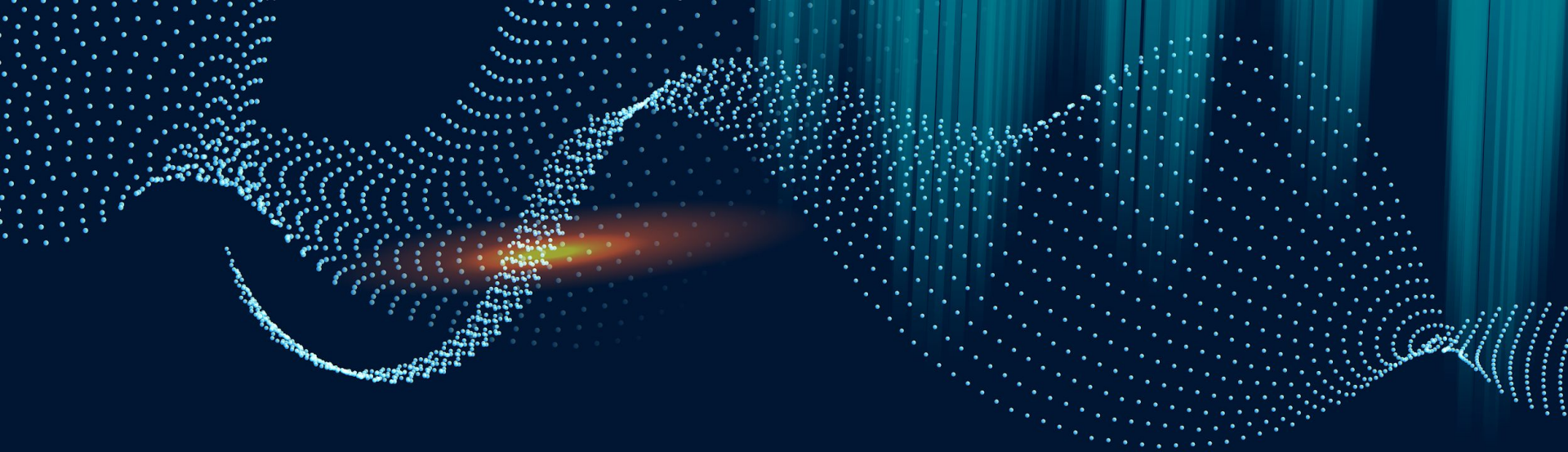
VECTORES DE ATAQUE

“Un vector de ataque es una vía o método utilizado por un atacante para acceder ilegalmente a una red o computadora en un intento de explotar las vulnerabilidades del sistema.”

—Fortinet

CICLO DE VIDA DEL ATAQUE





Muchas gracias

Nos vemos en la próxima clase